

30-day plan of action

Re-confirmation of docs/frontend-audit-2026-08.md (the original structural audit) against current main, commit 6c2e1df, plus every manual step and a sequenced 30-day roadmap for what remains. Six independent verification passes, one adversarial cross-check applied to every claim of 'fixed.'

Critical	High	Medium (named)	Pattern
1 of 7 fixed	2 of 21 fixed	2 of 9 fixed, 1 partial	1 of 5 fixed

Headline: none of this was in scope for the two PRs that just shipped

PR#8 and PR#9 implemented a separate audit (image and content generation). Whatever overlaps with the original structural audit here is incidental. Of the 42 individually-named findings across critical, high, named-medium and pattern-underneath categories: **6 fixed, 1 partial, 35 still open**. The redesign-blocker checklist -- five items the original audit said must be resolved before any visual work begins -- is **zero of five resolved**.

C2 -- live right now: the staleness banner fires purely on data age with zero reference to whether anything is priced. Verified by execution against today's date: the site is currently telling visitors prices 'may be outdated' above a page where every single price is null. One-line fix.

C4 -- the redesign trap: tools/qa.mjs still locates ~11 elements by CSS class name. Rename .card or .visually-hidden in a future redesign and the deploy gate reports a wrong price or a missing safety caveat -- not 'selector not found.' render.js still has zero direct tests.

What still holds: the site's core invariant -- never render a price it hasn't verified -- was re-tested by injection and still holds. Nothing above touches the honesty. It's all delivery.

What this document contains

A. Manual steps -- only you can do these, code cannot. **B.** A sequenced 30-day plan covering every remaining item, dev and owner alike. **C.** The full findings appendix: all 52 checked items (excluding exact duplicates), status, evidence and effort, for reference.

A. Manual steps -- only you can do these

Carried over from the prior handoff (docs/handoff/GLP1-Fund-remaining-actions.pdf) where still open, plus new items this re-confirmation surfaced. I cannot verify Cloudflare or email-provider state from this session -- if you've already done 1 or 2, check them off and move on.

- ☐ **1. Confirm the contact@glp1-fund.com mailbox actually receives mail**
It is printed on 4 pages as your corrections and CCPA/CPRA contact. If this was already done since the last handoff, check it off.
public/engine/config.js -> PUBLISHER.email
- ☐ **2. Confirm ALERTS_SECRET is set in Cloudflare Pages**
Unsubscribe fails closed without it. If already set, check it off.
Cloudflare Pages -> Settings -> Functions -> Environment variables
- ☐ **3. Send /privacy/ and /terms/ to a lawyer**
Confirmed still unreviewed as of this re-check. Both are accurate to what the code does; that is not the same as reviewed.
public/privacy/index.html, public/terms/index.html
- ☐ **4. Decide: is 730-day data retention correct for your business?**
I set a default and published it as a promise on the privacy page. Change it now, before anyone relies on it.
public/engine/config.js -> DATA_RETENTION_DAYS
- ☐ **5. Pick an email service and decide the alerts confirmation flow**
H5 confirmed unfixed: the alerts endpoint has no rate limiting and no confirmation step -- it will accept and store a breach dump, then eventually mail all of it. Decide now whether signup requires double opt-in (email a confirm link before indexing) or just rate limiting. This is a product decision before it is code.
functions/api/alerts.js
- ☐ **6. Decide the ad vendor before Content-Security-Policy can be written**
MEDIUM-5 confirmed unfixed: no CSP exists anywhere, on a site planning to inject third-party ad scripts into three slots. The CSP's script-src/frame-src depends entirely on which network you pick.
public/_headers
- ☐ **7. Decide: self-host a variable font, or accept fewer heading weights**
H21 confirmed unfixed: font-weight 650 collapses to bold on Android system fonts, flattening your whole heading hierarchy on the platform most of your traffic likely uses. The cheap fix (collapse to 400/700) is a visual decision, not just a code change.
public/assets/css/base.css
- ☐ **8. Verify actual prices**
Still blocked: every one of the 45 figures is unverified because this build's network refuses outbound connections to fda.gov, cms.gov, medicare.gov, trumpx.gov and all Lilly/Novo Nordisk domains. Needs a network that can reach them, or a manual read-and-paste of confirmed figures with citations.

B. 30-day plan of action

Sequenced by dependency and blast radius, not by the audit's own severity labels. C2 is 'only' medium effort but it is live and wrong today, so it leads. Redesign-blocking work comes before polish, because every day without it compounds the risk of a future redesign misdiagnosing its own failures.

Week 1 — stop what's actively wrong, in parallel with owner items above

ID	Action	Effort	Who
C2	Filter overallStaleness() to priced results only. It is firing incorrectly right now.	1 line + test	Dev
C1	Add DOCTYPE + html lang="en" to layout(); add compatMode/lang assertions to qa.mjs.	3 lines	Dev
H13	Add color-scheme:light (or a meta tag) so native controls stop rendering dark-on-white.	1 line	Dev
C5	Branch describeAge() on confidence so assistive text stops saying "verified" on unverified cards.	Small	Dev
MEDIUM-3	Validate officialUrl in validateDataset the same way source_url already is.	Small	Dev
H9	Add an /alerts/ link to the footer nav and/or a homepage callout.	Small	Dev
C6	Move aria-live off the whole results region; add a one-line status element outside it; debounce render().	Small	Dev

Week 2 — redesign readiness (0 of 5 blockers resolved; do this before any visual work)

ID	Action	Effort	Who
C4 / BLOCKER-1	Convert qa.mjs's ~11 class-name selectors to data-* hooks, in lockstep with render.js/CSS.	1-2 days	Dev
C4 / BLOCKER-2	Add test/render.test.js: source link + date on every card, monthlyCost===null never numeric, suppressed pathways excluded.	Half day	Dev
H8 / BLOCKER-3	Content-hash CSS/JS filenames, or drop /assets/* to revalidate-always as a stopgap.	Half-1 day	Dev
BLOCKER-4	Sweep qa.mjs's fold/overflow checks across 320x568, 375x667, 390x844, 768x1024, 1440x900.	Half day	Dev
H20 / BLOCKER-5	Add Network.emulateNetworkConditions + Emulation.setCPULthrottlingRate to the CLS check.	Half day	Dev
CONSTRAINT-1, 3	Move the CSS-URL-allowlist and affiliate-slot rules into v0-handoff.md, where a redesigner will actually look.	Under 1 hr	Dev

Week 3 — accessibility and robustness (the rest of the 21 high-severity items)

ID	Action	Effort	Who
H14	Fix select/input border contrast (measured 1.72:1 / 1.86:1; needs 3:1 for SC 1.4.11).	Small	Dev
H15,H16,H17	Fix the dangling aria-labelledby, restore list semantics on the ranked results, move the cost line after the h3.	Small	Dev
H18,H19	Associate the alerts validation error via aria-describedby; re-enable the submit button on success.	Small	Dev
H1,H2	Stop the false permanent "Loading" state on failed fetch; add a fetch timeout/retry/abort.	Small-Med	Dev
H3	Add method="post" action to the alerts form so no-JS visitors don't leak an email into the URL.	Small	Dev
H4	Make the two-step alerts KV write atomic-enough, or repair the index on the existing-subscriber path.	Medium	Dev
H5	Implement whatever Manual Step 5 decided: rate limiting and/or double opt-in.	Medium	Both
H10,H11,H12	Distinguish .empty from .ad-slot visually; move the disclaimer above the footer ad slot; fix print styles.	Small-Med	Dev

Week 4 — polish, content debt, and the two design calls left for your eye

ID	Action	Effort	Who
C7	Split --measure into prose/app/data tokens with real breakpoints; bound .table-scroll's height.	Half-1 day	Dev

ID	Action	Effort	Who
PATTERN-2,4	Fix the dead space under unverified cards; promote the "none verified" message out of the smallest type.	Small	Dev
PATTERN-5	Reorganize LillyDirect's caveats so the no-answer page isn't the longest read on the site.	Small	Dev
MEDIUM-4,6,8,9	Assert hasDataStamp in qa.mjs; consolidate .empty to one template; fix off-scale type and raw hex.	Small-Med	Dev
H21	Implement whatever Manual Step 7 decided about heading weights.	Medium	Both
MEDIUM-5	Write the CSP once Manual Step 6 names the ad vendor.	Small	Both
Carried over	Intro-pricing cliff diagram and empty-state redesign, from the prior handoff -- still deliberately unshipped design calls.	Design review	Owner

Not on this calendar: PATTERN-3 (renderSavings never fires) and real price verification. Both are the same underlying block -- nothing renders a saving until a real price is confirmed, and confirming a price needs the network access Manual Step 8 depends on. No amount of code work in weeks 1-4 moves this.

C. Full findings appendix

All 52 distinct checked items (the 6 'if you do only five things' entries are omitted here as exact duplicates of C1/C2/C3/C4/H6 above). STATUS reflects the adversarial cross-check, not the first-pass claim. Method: 6 parallel agents re-read current source and reproduced behaviour -- built the site, ran the engine directly, drove headless Chromium -- rather than trusting the original audit's prose; every FIXED claim was then independently re-checked by a 7th, adversarial agent before being accepted.

ID	Finding	Status	Effort
C1	No doctype/html/lang on any page — quirks mode, WCAG 3.1.1 fail	OPEN	trivial (few lines in one function plus a two-line qa.mjs assertion...
C2	Staleness banner can fire above a results list where every price is null	OPEN	trivial (one-line filter change plus a unit test)
C3	Site was anonymous, collected email, no privacy/terms/contact	FIXED	n/a (already fixed)
C4	qa.mjs coupled to presentational class names; render.js has zero tests	OPEN	half a day, per the audit's own estimate (qa.mjs migration + new test...
C5	Assistive text ("verified") contradicts visible text ("Not verified") on every card	OPEN	small (a few lines in describeAge plus its one call site, plus...
C6	aria-live="polite" on the whole results region can announce hundreds of words per keystroke; urgent banner nested inside it	OPEN	small (markup move + one debounce wrapper around render())
C7	Only a flat 640px column at every desktop width; evidence table clipped by 297px	OPEN	half a day to a day (CSS-only: new breakpoints, a couple of token...
H1	Failed data load overwritten by a false 'Loading' message on next interaction	OPEN	Small (a few lines in app.js)
H2	No fetch timeout, retry, or abort on the data load	OPEN	Small
H3	Without JS, the alerts form does a native GET with the email in the URL	OPEN	Small
H4	Alerts KV write is still a two-step non-transaction that can leave a subscriber unreachable behind an ok:true	OPEN	Medium
H5	Alerts endpoint has no rate limiting and no confirmation step	OPEN	Medium
H6	No og:image and no favicon	FIXED	n/a
H7	Meta descriptions truncated mid-word on pathway pages	FIXED	n/a
H8	Unhashed CSS/JS cached at max-age=3600 while HTML revalidates	OPEN	Medium
H9	Alerts CTA appears only in the masthead nav	OPEN	Small
H10	.empty and .ad-slot remain visually indistinguishable dashed boxes	OPEN	Small
H11	Footer ad slot renders directly above the medical disclaimer	OPEN	Small
H12	Print stylesheet loses every source URL and clips the evidence table	OPEN	small
H13	No dark mode / no color-scheme declared	OPEN	trivial
H14	Form control borders fail SC 1.4.11 non-text contrast	OPEN	small
H15	Results section's aria-labelledby is dangling on arrival	OPEN	small
H16	list-style:none strips list semantics from the ranked results list	OPEN	trivial
H17	"Lowest verified cost" paragraph precedes the h3, breaking heading navigation	OPEN	trivial
H18	Alerts validation error not associated with the field; focus races the announcement	OPEN	small

ID	Finding	Status	Effort
H19	Submit button never re-enabled on success	OPEN	trivial
H20	Results empty-state double layout shift, invisible to unthrottled qa.mjs	OPEN	medium
H21	font-weight 650 collapses to bold on Roboto/Arial/Helvetica, flattening heading hierarchy	OPEN	medium
MEDIUM-1	Stray full stop in .data-stamp due to display:flex splitting the trailing period into its own flex item	FIXED	n/a
MEDIUM-2	Changelog arithmetic error: '26 tracked price figures' vs 45 actual rows	PARTIAL	n/a
MEDIUM-3	officialUrl never validated by validateDataset, so esc() cannot neutralise a javascript: scheme reaching href	OPEN	small (a few lines + one test)
MEDIUM-4	Data stamp missing on /about/ and /alerts/; qa.mjs computes hasDataStamp but never asserts it	OPEN	a few lines
MEDIUM-5	No Content-Security-Policy, on a site intending to inject third-party ad scripts into three slots per page	OPEN	hours (needs the ad vendor's required origins first)
MEDIUM-6	.empty authored in five places across three files, so a redesign touching render.js updates only one of five	OPEN	half a day
MEDIUM-7	No JSON-LD on /methodology/, /changelog/, /about/, /alerts/ -- no Organization, dateModified, or Dataset	FIXED	n/a
MEDIUM-8	11px off-scale type in .pill and .ad-slot__label, below the smallest type-scale step	OPEN	1-2 lines
MEDIUM-9	Three raw hex values exist outside the CSS token block	OPEN	a few lines
PATTERN-1	H1 overpromised a ranked cheapest price while the tool ranked nothing	FIXED	n/a
PATTERN-2	.card__cost--unverified overrides font-size but not min-height, leaving dead space under unverified cards	OPEN	1 line
PATTERN-3	renderSavings only renders when a saving exists, so the biggest motivating number never appears	OPEN	n/a until real data / half a day for a teaser alternative
PATTERN-4	The 'none has a price we could verify' message is set in the smallest, faintest type on the page	OPEN	1-2 lines
PATTERN-5	The user who gets no answer (LillyDirect) receives more text than one who gets everything	OPEN	half a day
DEFENSE-CHECK	The site still refuses to print an unverified price as if verified	FIXED	n/a
BLOCKER-1	Decouple qa.mjs from presentational class names (dup of C4)	OPEN	1-2 days
BLOCKER-2	Add behaviour tests for render.js (dup of C4, second half)	OPEN	half a day
BLOCKER-3	Fix the cache story before any redesign (H8)	OPEN	half a day for the revalidate-always stopgap; ~1 day for real content...
BLOCKER-4	Extend qa.mjs beyond one viewport	OPEN	half a day
BLOCKER-5	Add network and CPU throttling to qa.mjs (dup of H20)	OPEN	half a day
CONSTRAINT-1	No external URLs in CSS — now documented anywhere outside the test file?	PARTIAL	under an hour
CONSTRAINT-2	No emoji anywhere, including CSS content: — now documented anywhere outside the test file?	FIXED	n/a
CONSTRAINT-3	.affiliate-slot display:none compliance control — now documented anywhere outside the test file?	PARTIAL	under an hour
CONSTRAINT-4	Ad slot heights and contain:layout size are CLS controls — now documented anywhere outside the test file?	FIXED	n/a
CONSTRAINT-5	Icons constrained to 24x24 viewBox / currentColor / no url() / no — now documented anywhere outside the test file?	FIXED	n/a